Кейс хакатона: Автоматическое обнаружение персональных данных в корпоративных файловых хранилищах

Описание проблемы

В ходе внутреннего аудита информационной безопасности крупной компании было обнаружено, что за годы работы на корпоративных файловых серверах накопилось большое количество файлов различного формата, которые хранятся без четкой структуры и классификации. Файлы разбросаны по различным директориям без единой системы организации.

Проблема заключается в том, что среди этих файлов могут находиться документы, содержащие персональные данные (ПДн) граждан, обработка которых регламентируется Федеральным законом № 152-ФЗ «О персональных данных». Несоблюдение требований законодательства в области защиты персональных данных может привести к серьезным штрафам и репутационным рискам для компании.

Ручной анализ таких объемов данных невозможен из-за масштаба задачи. Требуется автоматизированное решение, которое сможет:

1. Просканировать файловое хранилище со смешанной структурой файлов
2. Определить, какие файлы или группы файлов содержат персональные данные
3. Классифицировать найденные ПДн по категориям в соответствии с российским законодательством
4. Сформировать отчет о результатах анализа

Постановка задачи

Участникам хакатона предлагается разработать программное решение (скрипт или приложение), которое обладает следующими возможностями:

Основные требования:

1. **Сканирование файловой структуры**: Решение должно рекурсивно обходить указанную директорию и анализировать файлы различных форматов:
    - Структурированные данные: CSV, JSON, Parquet
    - Документы: PDF, DOC, DOCX, RTF, XLS
    - Веб-контент: HTML
    - Изображения: TIF, JPEG, PNG, GIF
    - Видео: MP4
2. **Извлечение текстовых данных**: Для файлов разных форматов необходимо реализовать механизмы извлечения текста:
    - Для структурированных форматов (CSV, JSON, Parquet) — парсинг структуры данных
    - Для документов (PDF, DOC, DOCX) — извлечение текста из документов
    - Для изображений — использование OCR (опционально, для повышения качества)
    - Для HTML — извлечение текстового контента
3. **Обнаружение персональных данных**: Решение должно выявлять следующие категории ПДн в соответствии с требованиями 152-ФЗ:
    - **Обычные персональные данные**:
        - ФИО (фамилия, имя, отчество)
        - Контактная информация (телефоны, email-адреса)
        - Дата и место рождения
        - Адреса проживания/регистрации
    - **Государственные идентификаторы**:
        - Паспортные данные РФ (серия, номер)
        - СНИЛС
        - ИНН (физических и юридических лиц)
        - Водительское удостоверение
        - MRZ (машиносчитываемая зона документов)
    - **Платежная информация**:
        - Номера банковских карт (с проверкой алгоритма Луна)
        - Банковские счета и БИК

        - CVV-коды
    - **Биометрические данные**:
        - Упоминания биометрических характеристик (отпечатки пальцев, радужная оболочка глаза, голосовые образцы и т.п.)
    - **Специальные категории ПДн**:
        - Данные о состоянии здоровья
        - Религиозные и политические убеждения
        - Расовая и национальная принадлежность
        - Иная информация, относящаяся к специальным категориям по 152-ФЗ
4. **Классификация уровня защищенности**: На основе обнаруженных категорий ПДн решение должно определять требуемый уровень защищенности (УЗ) информационной системы:
    - **УЗ-1**: Наличие специальных категорий ПДн или биометрических данных (высокий риск)
    - **УЗ-2**: Наличие платежной информации или государственных идентификаторов в больших объемах
    - **УЗ-3**: Наличие государственных идентификаторов в небольших объемах или обычных ПДн в больших объемах
    - **УЗ-4**: Наличие только обычных ПДн в небольших объемах (базовый уровень)
5. **Формирование отчета**: Решение должно генерировать структурированный отчет, содержащий:
    - Путь к файлу
    - Список обнаруженных категорий ПДн
    - Количество найденных экземпляров каждой категории
    - Определенный уровень защищенности (УЗ)
    - Формат файла
    - Рекомендации по обработке (опционально)

Формат выходных данных

Отчет должен быть представлен в одном из следующих форматов:

- CSV файл с колонками: `путь`, `категории_ПДн`, `количество_находок`, `УЗ`, `формат_файла`
- JSON файл со структурированными данными
- Markdown отчет с визуализацией результатов

Структура тестового датасета

Тестовый датасет представляет собой смешанную файловую структуру, имитирующую корпоративное хранилище. Датасет включает более **3000 файлов** различных форматов общим объемом около **3 ГБ**

Особенности датасета:

- Разнообразие форматов файлов (более 10 различных типов)
- Смешанная структура данных (структурированные, неструктурированные, бинарные)
- Большие объемы данных в структурированных файлах (десятки и сотни тысяч записей)
- Наличие документов в изображениях, требующих OCR
- Файлы различных размеров (от нескольких килобайт до десятков мегабайт)

Важно: Файлы в датасете будут перемешаны и размещены в общей директории для имитации реальной ситуации с неорганизованным хранилищем. В реальных корпоративных условиях объем данных может быть в десятки и сотни раз больше, но тестовый датасет достаточен для проверки корректности и производительности решения.

Критерии оценки решений

Решения участников будут оцениваться по следующим критериям:

1. **Точность обнаружения ПДн** (40%):
    - Полнота выявления всех категорий персональных данных
    - Минимизация ложноположительных срабатываний
    - Корректность валидации обнаруженных данных (например, проверка алгоритмом Луна для банковских карт)
2. **Качество классификации** (25%):
    - Правильность определения уровня защищенности (УЗ)
    - Соответствие классификации требованиям 152-ФЗ

3. **Производительность и масштабируемость** (20%):
    - Скорость обработки файлов различных форматов
    - Эффективность использования ресурсов (память, CPU)
    - Возможность обработки больших файлов и больших объемов структурированных данных
    - Оптимизация обработки изображений и OCR (при использовании)
    - Способность решения масштабироваться на большие объемы данных
4. **Качество отчета** (10%):
    - Структурированность и читаемость отчета
    - Полнота представленной информации
    - Удобство для дальнейшего анализа
5. **Техническая реализация** (5%):
    - Качество кода
    - Обработка ошибок
    - Документация решения

Технические требования

- Язык программирования: Python 3.10+ (рекомендуется)
- Разрешается использование любых открытых библиотек
- Решение должно быть запускаемым из командной строки
- Решение должно обрабатывать ошибки чтения файлов (поврежденные файлы, неподдерживаемые форматы)
- Решение не должно требовать ручного вмешательства в процессе работы
- Решение должно быть предоставлено в легко воспроизводимом виде

Этические и правовые аспекты

- Дисклеймер: все ПДн в датасете, либо являются реальными, но опубликованы самим субъектом (и исключаются из правила о защите ПДн), либо являются вымышленными (сгенерированными) и не нарушают реальных правовых ограничений

- Однако, в условиях иммитации реального кейса, участники должны помнить, что работа ведется с данными, которые могут содержать персональную информацию
- В отчетах не должны сохраняться исходные значения персональных данных — рекомендуется использовать маскирование или хеширование
- Решение должно соответствовать принципам конфиденциальности и безопасности данных
- При обнаружении ПДн решение должно фокусироваться на факте наличия данных, а не на их конкретных значениях

Дополнительные рекомендации

- Рекомендуется использовать регулярные выражения для поиска паттернов ПДн
- Для валидации данных (номера карт, СНИЛС, ИНН) следует использовать соответствующие алгоритмы проверки
- Для обработки изображений можно использовать библиотеки OCR (Tesseract, EasyOCR)
- Для обработки PDF рекомендуется использовать несколько библиотек для повышения качества извлечения текста
- Стоит учитывать различные форматы представления одних и тех же данных (например, телефонные номера могут быть записаны по-разному)

Ожидаемый результат

По итогам выполнения задачи участники должны предоставить:

1. Исходный код решения (репозиторий GitHub или архив)
2. Инструкцию по запуску решения
3. Отчет с результатами анализа тестового датасета
4. Краткое описание использованных алгоритмов и подходов

Удачи в решении задачи!